

PROYECTO – Entrega No. 2: Despliegue y Controles de seguridad para una aplicación en la nube.

INTRODUCCIÓN

En esta etapa del semestre, continuará utilizando la aplicación desarrollada en la entrega anterior del curso. En esta etapa desplegará la aplicación en la nube de su elección (GCP o AWS), implementará diferentes servicios que robustecerán la seguridad de la solución en la nube y brindarán una capa adicional para mejorar la postura global seguridad en sus ambientes. Finalmente se aplicarán los conceptos teóricos estudiados en esa fase del curso.

- **Aprovechamiento del Stack:** Se recomienda seguir usando Python (FastAPI) y React, ya que la arquitectura de capas definida en la fase anterior (Handlers, Services, Repositories) facilita enormemente la migración a servicios de nube.
- **Portabilidad:** El éxito de esta fase depende de que el requerimiento **RNF-08** (Dockerización) se haya cumplido rigurosamente.

DESCRIPCIÓN DE LAS TAREAS A IMPLEMENTAR

1. Objetivo General

Evolucionar la plataforma LiveMenu desde un entorno de contenedores local hacia una **infraestructura productiva en la nube pública (AWS o GCP)**, garantizando la alta disponibilidad, la integridad de los datos y la implementación de estándares avanzados de seguridad informática.

2. Alcance del Despliegue en Nube

El equipo debe migrar los componentes definidos en la arquitectura original a servicios gestionados, asegurando que el sistema sea capaz de soportar la carga de una plataforma SaaS con múltiples sucursales.

- **Capa de Aplicación:** Desplegar el backend (FastAPI) y el frontend (React) utilizando servicios de orquestación o serverless (ej: AWS ECS/Fargate o GCP Cloud Run).
- **Capa de Datos:** Migrar la base de datos PostgreSQL a un servicio administrado como **AWS RDS** o **GCP Cloud SQL**, configurando alta disponibilidad (Multi-AZ).

- **Almacenamiento de Imágenes:** Implementar el uso definitivo de **AWS S3** o **Google Cloud Storage** para las variantes de imágenes (thumbnail, medium, large) generadas por el worker pool.

3. Requerimientos de Seguridad y Gestión de Datos

Para esta fase, se deben implementar las siguientes capas de protección sobre los requerimientos no funcionales ya existentes:

3.1. Cifrado y Protección de Datos

- **Cifrado en Reposo (At-Rest):** Configurar el cifrado de la base de datos PostgreSQL y de los buckets de Object Storage utilizando claves administradas por el proveedor de nube.
- **Cifrado en Tránsito (In-Transit):** Garantizar que todas las comunicaciones, no solo las de administración sino también el acceso al menú público, se realicen estrictamente sobre **HTTPS/TLS**.

3.2. Gestión Avanzada de Secretos y Claves

- **Eliminación de Archivos .env:** Se prohíbe el uso de archivos .env en producción. Todas las credenciales de base de datos, llaves de API y el secreto para la generación de **JWT** deben gestionarse a través de **AWS Secrets Manager** o **GCP Secret Manager**.
- **Rotación de Claves:** Implementar una política de **rotación automática de secretos** (mínimo cada 40 días) para las credenciales de acceso a la base de datos y la clave de firma de los tokens JWT.
- **Manejo de Identidades (IAM):** Aplicar el principio de "menor privilegio", configurando roles de ejecución específicos para que los servicios solo tengan acceso a los recursos necesarios (ej: el backend solo puede escribir en su propio bucket de imágenes).

4. Estrategia de Continuidad y Backup

Dada la importancia de mantener la integridad de los menús y la configuración de los restaurantes, se requiere:

- **Backups de Base de Datos:** Configurar copias de seguridad automáticas y diarias para la base de datos PostgreSQL gestionada (RDS/Cloud SQL) con una retención mínima de 15 días.

- **Resiliencia de Imágenes:** Implementar el versionamiento de objetos en el **Object Storage (S3/GCS)** para prevenir borrados accidentales de los logos y fotos de platos procesados por el *worker pool*.
- **Definición de RPO/RTO:** El equipo debe documentar el Punto de Recuperación Objetivo (RPO) y el Tiempo de Recuperación Objetivo (RTO) para asegurar que se cumpla con el **99.9% de uptime** exigido para el menú público. (Esto es más documental no de implementación).

5. Análisis de Seguridad de Contenedores y Aplicación.

Considerando que la aplicación debe ser portable mediante Docker, se solicita:

- **Escaneo de Vulnerabilidades:** Implementar un proceso de análisis estático sobre las imágenes de contenedores del backend y frontend para detectar vulnerabilidades conocidas (CVEs) en las librerías de Python y Node.js.
- **Hardening de Imágenes:** Las imágenes Docker deben basarse en distribuciones ligeras y seguras (como python:3.12-slim o alpine), siguiendo las mejores prácticas para reducir la superficie de ataque.
- **Integración en CI/CD:** El despliegue a la nube debe estar condicionado a que el escaneo de seguridad no arroje vulnerabilidades de criticidad "Alta" o "Crítica".

6. Implementación de Web Application Firewall (WAF)

Para proteger la infraestructura de ataques a nivel de aplicación, se requiere:

- **Protección Perimetral:** Desplegar un servicio de **WAF (AWS WAF o Google Cloud Armor)** frente al punto de entrada de la aplicación (Load Balancer o Ingress).
- **Mitigación de Riesgos:** El WAF debe estar configurado para mitigar ataques comunes del **OWASP Top 10** (como inyección SQL o Cross-Site Scripting) y reforzar el **Rate Limiting** ya definido en los middlewares de la API.
- **Filtrado Geográfico:** Opcionalmente, configurar reglas para permitir o bloquear tráfico basado en la ubicación geográfica de los clientes, optimizando el rendimiento del menú público para los mercados objetivo.

7. Opcional – IaC:

- **Infraestructura como Código (IaC):** Scripts (Terraform o CloudFormation) que definan la red, la base de datos y el cómputo.

ENTREGABLES

- Diagrama de arquitectura actualizada de la solución desplegada en GCP o en AWS.
- Documentación del proyecto teniendo en cuenta que se incluya la configuración de los controles de seguridad, detalles de los nuevos servicios y las mejores prácticas aplicadas. Documentación que detalle la estrategia de cifrado utilizada, el esquema de rotación de claves, la configuración del WAF y demás componentes de seguridad.
- Informe de seguridad con las vulnerabilidades encontradas sobre en las imágenes de contenedores y en la aplicación desplegada, priorizando las más críticas.
- Demostración de los controles de seguridad sobre la aplicación desplegada en GCP. Realice un video con una duración máxima de 8 minutos en el que presente los controles de seguridad de su aplicación. Enlace el video al repositorio correspondiente.
- Repositorio Git (Github/Gitlab).

Nota: El monitor puede solicitar una sustentación síncrona, independiente a la video sustentación. Se recomienda dejar el ambiente configurado para dicho propósito, aunque pueden estar apagados los recursos para no gastar la totalidad de créditos.

ESQUEMA DE EVALUACIÓN

Criterio	Peso	Excelente (86-100%)	Satisfactorio (61-85%)	Insuficiente (<60%)
Despliegue en Nube (GCP/AWS)	20%	Despliegue completo en servicios gestionados en Nube (Cloud Run/ECS, RDS/Cloud SQL).	Despliegue funcional en la nube, pero con configuración manual o sin alta disponibilidad.	La aplicación no es accesible en la nube o solo funciona localmente.
Arquitectura	10%	Capas claras, servicios de nube completos y con relaciones específicas.	Algunas capas claras y ciertos servicios especificados.	Sin estructura clara.
Cifrado y Protección de Datos	15%	Cifrado At-Rest activo en DB y Storage, y comunicación 100% por HTTPS/TLS con certificados válidos.	Cifrado implementado solo en tránsito (HTTPS) o solo en reposo, pero no ambos.	Datos sensibles (DB) y archivos en storage viajan o se almacenan en texto plano.
Gestión de Secretos y Claves	15%	Cero uso de archivos .env. Integración total con Secrets Manager, incluyendo política de rotación de claves funcional.	Uso de Secrets Manager pero con algunas credenciales aún en código o sin rotación automática.	Credenciales expuestas en el código fuente o archivos .env subidos al repositorio.
Estrategia de Backup	5%	Backups automáticos diarios documentados con política de retención y versionamiento en Object Storage. Definición clara de RPO/RTO.	Copias de seguridad manuales o sin automatización clara de la retención de datos.	No existe un plan de respaldo ni mecanismos de recuperación de datos ante fallos.

Análisis de Seguridad	15%	Escaneo de vulnerabilidades integrado en el pipeline de CI/CD que bloquea el despliegue ante riesgos críticos. Uso de herramienta de nube para escaneo general.	Escaneo realizado de forma manual o reporte de vulnerabilidades sin plan de mitigación ni priorización.	No se realizan análisis de seguridad sobre las imágenes de Docker. Ni escaneo general.
WAF	15%	WAF configurado con reglas contra OWASP Top 10 y Rate Limiting activo. Grupos de seguridad siguiendo el principio de menor privilegio.	Implementación básica de WAF o solo protección mediante Rate Limiting en el middleware de la API.	Aplicación expuesta directamente a internet sin capas de filtrado perimetral.
Trabajo en equipo	5%	Commits balanceados, PRs con reviews, buena comunicación y aportes de todo el equipo.	Colaboración parcial de los integrantes.	Sin evidencia de colaboración.